



Software Development and ICT Change Management Guideline

Version: 2.0

Valid From Date: 19.08.2026

Last Review Date: 14.08.2026

Notes: This written rule uses gender-neutral and inclusive language. Whenever possible, the generic masculine is avoided and all employees of any gender identity (m/f/d) are addressed.

Content changes compared to the previous document version are highlighted in color.

Content

1. Purpose, Objectives and Basis	3
1.1. Purpose and Objectives	3
1.2. Basis of this Guideline	4
2. Functional Scope and Target Groups	5
2.1. Functional scope of applicability	5
2.2. Target groups	5
2.3. Transition period	6
3. Definitions	7
3.1. Requirements	7
3.2. Explanation of requirements and key definitions	8
4. Requirements	9
4.1. Requirements	9
4.1.1. ICT Change Management	9
4.1.2. Software Development	20
4.1.3. Project Management	28
5. Roles and Responsibilities	29
5.1. Creator	29
5.2. Guideline Owner	29
6. Appendix	30
6.1. Contact Information	30
6.2. Document History	30
6.3. Related Written Rules	30
6.4. Abbreviations	31

1. Purpose, Objectives and Basis

1.1. Purpose and Objectives

The Software Development and ICT Change Management Guideline (hereinafter “Guideline”) establishes control requirements for DBAG and/or adopting Legal Entities within DBG (refers only to Legal Entities that have ratified the Guideline at hand) and provides criteria for fulfilling the control requirements.

The purpose of the Guideline is to effectuate the below listed Minimum Requirements, stipulated in the ICT Risk Management Policy (structured into Core Functions), acting as objectives to the Guideline and the control requirements at hand:

Core Function	Minimum Requirement	ICT Risk Management Policy chapter
Govern	2. Allocate roles and responsibilities as detailed in chapter 5 in the ICT Risk Management Policy.	4.1
Govern	6. Have in place a mechanism to define and document responsibilities for implementing control requirements both within and outside IT and IS (e.g. HR). This can be documented e.g. as part of the ICT Control Framework (former Mandatory Control Framework (MCF)) .	4.1
Identify	1. Identify and record assets (e.g. data, hardware, software, systems, facilities, services, people) including respective interdependencies and classify these assets with their relative importance to organizational objectives (including security objectives) and the organization's risk strategy.	4.2
Identify	4. Establish an ICT risk management process and perform ICT risk assessment on a regular basis and in the event of major changes, considering threats and vulnerabilities covering different IT assets (e.g. applications) and Non-IT assets (e.g. buildings, rooms) in a consistent way taking into consideration asset-specific differences in the assessment approach.	4.2

Protect	1. Design and implement ICT risk management control requirements to achieve the protection goals and integrating them to the ICT Written Rules framework. These control requirements are including but not limited to ICT operations and physical and environmental security, network and infrastructure management, encryption and cryptographic controls, identity management and logical/physical access control, software development, change and project management, threat management, patch and vulnerability management, human resources, and third-party management, AI, IDP & NCLC¹, data management and other controls addressing poor administration and human error risks.	4.3
----------------	--	-----

Table 1: Minimum Requirements

Note: The full list of Core Functions and Minimum Requirements is stipulated in the ICT Risk Management Policy.

1.2. Basis of this Guideline

The basis for this Guideline is the **thematically linked** ICT Risk Management Policy.

¹ IDP refers to Individual Data Processing, and NCLC refers to No-Code/Low-Code solutions.

2. Functional Scope and Target Groups

2.1. Functional scope of applicability

Entity	DBAG or adopting LE within DBG
Area	DBAG CIO / COO Division; Chief Risk Officer Area; or any other area that manages or owns Software Development and ICT Change topic

Table 2: Scope

2.2. Target groups

Within the scope of the current Software Development and ICT Change Management Guideline below is addressed the list of applicable target groups and operation areas²:

Target group	Key message
Management Body	To ensure the awareness of the importance of software development and ICT Change management for strategic decision-making.
ICT Risk Oversight	To oversee the enforcement of security policies and ensure that all software changes and developments comply with DBG cybersecurity framework.
ICT Operational Management	To implement and manage software changes and ensure they align with existing IT infrastructure and security standards.
Business Management	To implement and manage software development solutions and controls and monitor for potential software issues ensuring the security and integrity of systems and data.

Table 3: Target groups

² For LE Guidelines adoption process the target groups should be adjusted according to organizational structure of the LE.

2.3. Transition period

The grace period for new requirements commences from the “valid from” date stated on the cover page. The compliance dates for control requirements defined in this version of the Guideline are defined as follows:

- For unchanged control requirements and new DORA requirements the compliance date equals the “valid from” date.
- For new and changed control requirements that are more stringent than before and are not subject to DORA, the compliance date is generally 90 calendar days after the “valid from” date unless otherwise stated in brackets after the control requirements. These control requirements are marked with ●.
- For Legal Entities that have not previously approved the IT-related requirements and are therefore addressing these requirements for the first time, a grace period of 90 days may be granted at the discretion of the Legal Entity. DORA requirements are exempt from this grace period.

For a **compliance date** exceeding a 180 calendar days implementation timeline, a Board approval is required.

3. Definitions

3.1. Requirements

Control requirement

The control requirements define the organizational, process or technical controls to be implemented by the control owner to achieve compliance with this Guideline.

Criteria

Criteria define the measures that 'must' or 'should' be taken to fulfill the control requirement.

Level of obligation

With respect to requirements and criteria, the following terms are used to define the level of obligation, provided for the implementation of a particular requirement or criteria:

- **“must”**: Mandatory control requirements / criteria derived directly from law, regulations, or internal specifications that the legal entity must comply with. Incompliance could result in consequences with external regulators and Internal Audit.
- **“should”**: Non-mandatory control requirements / criteria derived from best-practice frameworks or equivalent sources that the legal entity does not have to necessarily comply with. Under specific circumstances there may exist valid reasons to ignore a particular control requirement, but the full implications must be understood and carefully weighed.

Independent of the level of obligation of a given requirement or criteria, it is allowed to deviate from single requirements or criteria in individual cases. However, a control requirement deviation always requires the conduction of a risk assessment and risk management including adequate risk acceptance and/or mitigation.

Any deviation from the Guideline denotes an exemption. The respective Information Owner makes decisions on such exemptions. Information Owners can only decide on risks with impact exclusively in their area of responsibility.

Responsibilities

The responsibility for fulfilling control requirements may be distributed across the organization, e.g., multiple Sections, Units, or Departments. In some cases, one Unit may be responsible for both the design and implementation of measures. In other cases, one Unit may be responsible for the design of measures, and another Unit may be responsible for the implementation of the measures. In addition, multiple Units may be responsible to collectively fulfill one requirement.

The precise responsibilities are to be defined in the underlying Procedure documents (e.g. via RACI matrices).

The ICS, among its various functionalities, registers Process Operators (PO) and Risk Representatives (RRs) mapped to the corresponding processes, controls, and risks which the RRs and/or POs are responsible for managing on behalf of the part of the organization that utilize their services (e.g. Asset Owners). For more information on ICS, please refer to the DBG ICS Guideline.

3.2. Explanation of requirements and key definitions

Control requirements are defined in a standardized format and are structured into the following components:

<Specify ID: xx (version x)>	<Name of control requirement (e.g. Access to production data)>
1	<Description of the control requirement>
1.1 1.1.1	<Lists the criteria applying to the control requirement> <Lists the sub-criteria applying to the control requirement> Asset-Types: <Lists asset types applicable to the control requirement> Key references: <Lists key regulatory references and industry best practice requirements affecting this control requirement (e.g., ISO/IEC 27001:2022 A.5.10, A.8.1)>

The terms in this document are defined in the overall ICT Risk Glossary, which is provided on the Intranet website.

4. Requirements

4.1. Requirements

4.1.1. ICT Change Management

ID: 1 (version 2.0)	General Change Management Requirements
1 DOR.ICT.SDC.GEN.001	It must be ensured that an ICT Change management process is in place to manage changes to IT Assets and non-IT Assets.
1.1 DOR.ICT.SDC.GEN.002	An ICT Change management process must be in place to ensure the controlled and systematic handling of ICT Changes and must cover at least the IT Assets software, hardware, network, firmware components, systems, security parameters, roles, and responsibilities. Asset-Types: Information, Business Process Key References: DORA RTS RMF A.17.2a)
1.2 DOR.ICT.SDC.GEN.003	The ICT Change management process must contain at least the following steps: – Formal documentation – Classification – Prioritization – Authorization – Approval – Testing – Implementation – Validation – Reporting Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.32
1.3 DOR.ICT.SDC.GEN.004	During the ICT Change management process the following measures and mechanisms must be applied: Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.17.1h)
1.3.1 DOR.ICT.SDC.GEN.005	The identification of the potential impact of ICT Changes on existing ICT security measures and an assessment of whether such change requires the adoption of additional ICT security measures. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.17.1h)

1.3.2 DOR.ICT.SDC.GEN.006	Mechanism to ensure the segregation between the function to approve changes and the functions responsible for requesting and implementing those changes. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.17.2b)
1.3.3 DOR.ICT.SDC.GEN.007	Clear description and segregation of duties of roles and responsibilities. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.32
1.3.4 DOR.ICT.SDC.GEN.008	Fallback procedures and responsibilities including procedures, triggering conditions and responsibilities for aborting changes or recovering from unsuccessful implementation. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.17.1e)
1.3.5 DOR.ICT.SDC.GEN.009	Documentation and communication of ICT Change details including the purpose, scope, timeline of implementation and expected outcomes of the change. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.17.1d)
1.4 DOR.ICT.SDC.GEN.010	Documented processes must be implemented to ensure that ICT Changes are controlled and deployed in Red Segregation Area securely. This includes changes to organizational structure, ICT security-relevant processes, and changes that have an impact on information security processes. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.32

ID: 2 (version 2.0)	ICT Change Types
2 DOR.ICT.SDC.CHG.001	It must be ensured that each change is classified and handled accordingly.
2.1 DOR.ICT.SDC.CHG.002	Each change must be assigned to the following two change types: Asset-Types: Business Process Key References: MaRisk 7.2 No 3 8.2 No. 1
2.1.1 DOR.ICT.SDC.CHG.003	Normal ICT Change: Normal ICT Changes adhere to every step outlined in the ICT-Change Management Processes. Asset-Types: Business Process Key References: MaRisk 7.2 No 3 8.2 No. 1
2.1.2 DOR.ICT.SDC.CHG.004	Emergency ICT Change: Emergency ICT Changes are ICT Changes that require immediate implementation due to a high risk of service failure or prevention of an imminent service impact ³ . Asset-Types: Business Process Key References: MaRisk 7.2 No 3 8.2 No. 1
2.2 DOR.ICT.SDC.CHG.005	There may also be additional subordinate change types ⁴ . These must comply with the specifications of this Guideline but may contain deviations in the order of process steps ⁵ . Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.32
2.3 DOR.ICT.SDC.CHG.006	An ICT Change is significant if it affects the security of assets supporting critical or important functions, decreases the security level, affects security features of IT Assets, or impacts any security-relevant components of the system ⁶ . Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.32

³ E.g. service outage, critical incident, security breach or exploited vulnerabilities, data loss, reputational damage etc.

⁴ E.g. pre-approved changes, expedited changes

⁵ E.g. approval, documentation

⁶ Significant Change has to be defined in more detail at the LE level in the CM procedure and map to "Major" change,

ID: 3 (version 2.0)	Emergency Changes
3 DOR.ICT.SDC.EMG.001	It must be ensured that emergency changes are handled according to the defined process.
3.1 DOR.ICT.SDC.EMG.002	As part of the ICT Change management process, procedures, protocols, and tools that provide adequate safeguards must be defined and established to manage Emergency ICT Changes. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.17.1f)
3.2 DOR.ICT.SDC.EMG.003	Emergency ICT Changes that meet the defined criteria may be implemented without an implementation plan, testing, documentation, or risk assessment. Following implementation, these changes must undergo a retrospective review, risk assessment, testing, documentation, and formal approval to the same extent as normal ICT Changes if not already existing. Asset-Types: Business Process Key References: MaRisk 7.2 No 3 8.2 No. 1
3.3 DOR.ICT.SDC.EMG.004	The implementation of Emergency ICT Change must be guided by the professional assessment of the team overseeing production systems and the business. Asset-Types: Business Process Key References: MaRisk 7.2 No 3 8.2 No. 1

ID: 4 (version 2.0)	Change Documentation
4 DOR.ICT.SDC.DOC.001	It must be ensured that every change has formal documentation.
4.1 DOR.ICT.SDC.DOC.002	All upcoming changes must be recorded and processed in the form of an ICT Change ticket including at least the following information: – Unique ID and time stamp – Reason and description – Affected IT Assets, processes, units – Target date – Category – Priority – Possible effects of implementation and non-implementation and the resulting risks – Where applicable, resources and budget owner required – Fall-back procedure or other mitigation measures – Applicant, approver – Change Record Request Status

	– Where applicable, link to related changes or incident Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.32
4.2 DOR.ICT.SDC.DOC.003	If no fall-back procedures or recovery mechanisms are available, a risk-based approach and associated mitigating measures must be performed. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.32
4.3 DOR.ICT.SDC.DOC.004	All steps of the change management process must be documented to achieve a comprehensive and detailed record of activities, decisions, communications, approvals, and actions taken. Asset-Types: Business Process Key References: MaRisk 7.2 No 3 8.2 No. 1
4.4 DOR.ICT.SDC.DOC.005	Documentation impacted by the change must be updated. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.32

ID: 5 (version 2.0)	Change verification and assessment
5 DOR.ICT.SDC.CVA.001	It must be ensured that the feasibility and associated risks of the change are evaluated.
5.1 DOR.ICT.SDC.CVA.002	It must be ensured that the desired solution is feasible and aligned with business needs. Asset-Types: Business Process Key References: ICT Risk Framework 1.0
5.2 DOR.ICT.SDC.CVA.003	It must be ensured that the risks, security requirements and impacts of ICT Changes are assessed and appropriately documented including assignment to a change type. Asset-Types: Business Process Key References: ICT Risk Framework 1.0
5.3 DOR.ICT.SDC.CVA.004	A risk assessment must be performed for significant changes and the regular risk assessment process must be followed.

	Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.32
--	---

ID: 6 (version 2.0)	Change approval
6 DOR.ICT.SDC.APP.001	It must be ensured that every ICT Change is approved.
6.1 DOR.ICT.SDC.APP.002	The approval level for every ICT Change must be defined and executed based on the results of the risk assessment. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.32
6.2 DOR.ICT.SDC.APP.003	A Change Advisory Board (CAB) must approve changes to IT Assets in production or impacting production data and emergency changes. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.32

ID: 7 (version 2.0)	Change Testing
7 DOR.ICT.SDC.TST.001	It must be ensured that ICT Changes are tested sufficiently.
7.1 DOR.ICT.SDC.TST.002	All ICT Changes must be tested to ensure they meet acceptance criteria. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.32
7.2 DOR.ICT.SDC.TST.003	ICT Changes must be tested in the Yellow, Blue or Green Segregation Area before promotion to Red Segregation Area. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.32
7.3 DOR.ICT.SDC.TST.004	The Yellow Segregation Area must be (nearly) identical to the Red Segregation Area. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Storage, Server & Host Hardware Key References: DORA RTS RMF A.16.1b.ii)
7.4 DOR.ICT.SDC.TST.005	Significant changes on IT Assets must be tested by simulating stressed conditions. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance,

	Operating System, Cloud PaaS, Container, Storage, Server & Host Hardware Key References: DORA RTS RMF A.17.2
7.5 DOR.ICT.SDC.TST.006	For significant changes, the following potential stakeholders must be involved appropriately in the design and conduction of tests: – Clearing members and clients – Interoperable central counterparties – Users – Critical utilities – Critical service providers – Other central securities depositories – Other market infrastructures – Other institutions with which central securities depositories have identified interdependencies in their ICT business continuity policy – Other interested parties Asset-Types: Business Process Key References: DORA RTS RMF A.17.2
7.6 DOR.ICT.SDC.TST.007	Tests and their results must be documented. Asset-Types: Business Process Key References: MaRisk 7.2 No 3 8.2 No. 1

ID: 8 (version 2.0)	Change Implementation
8 DOR.ICT.SDC.IMP.001	It must be ensured that changes are implemented effectively.
8.1 DOR.ICT.SDC.IMP.002	The following steps must be carried out during change implementation, where feasible with the support of a change implementation plan: – Describe the sequence of implementation steps and timing of the roll-out. – Describe resource requirements (if specific, requirements should be considered). – Describe identified inter-dependencies and the interaction with other changes and how they are managed. – Describe the criteria for successful production implementation. – Describe installation verification requirements (if necessary and applicable). – Describe fallback procedures. – Identify and update all relevant documents impacted by the change implementation (e.g. business processes, system documentation, configuration details, and security concepts). – Address key risks in the plan and formally review them including technical and business risks. – Include an appropriate test plan. – Include approval by affected Application Owners, if not already approved during change approval in ID 6.

	Asset-Types: Business Process Key References: MaRisk 7.2 No 3 8.2 No. 1
8.2 DOR.ICT.SDC.IMP.003	It must be ensured that changes are implemented within the agreed time frames (as defined in procedural or process level documents). Asset-Types: Business Process Key References: MaRisk 7.2 No 3 8.2 No. 1
8.3 DOR.ICT.SDC.IMP.004	Where appropriate after change implementation, training regarding the change must be provided. Asset-Types: Business Process Key References: DORA RTS RMF A.17.1e)

ID: 9 (version 2.0)	Change Review
9 DOR.ICT.SDC.REV.001	It must be ensured that the documentation on the changes is reviewed, and a post-implementation review is carried out.
9.1 DOR.ICT.SDC.REV.002	A post-implementation review must be conducted to evaluate whether the change met its objectives and to identify areas for improvement and included in the change ticket. Asset-Types: Business Process Key References: MaRisk 7.2 No 3 8.2 No. 1
9.2 DOR.ICT.SDC.REV.003	All documentation must be reviewed and checked against the ICT Change requirements. Asset-Types: Business Process Key References: MaRisk 7.2 No 3 8.2 No. 1

ID: 10 (version 2.0)	Change Reporting
10 DOR.ICT.SDC.REP.001	It must be ensured that relevant stakeholders are regularly informed about change activities.
10.1 DOR.ICT.SDC.REP.002	Communication regarding the change must be made to all relevant stakeholders or potentially impacted entities in a timely manner. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.32
10.2 DOR.ICT.SDC.REP.003	Regular reports must be generated and distributed, covering change management activities, process performance, compliance, and, where appropriate, relevant KPIs and metrics. Asset-Types: Business Process Key References: MaRisk 7.2 No 3 8.2 No. 1

ID: 11 (version 2.0)	Change Logging
11 DOR.ICT.SDC.LOG.001	It must be ensured that ICT Change management relevant events are logged.
11.1 DOR.ICT.SDC.LOG.002	All ICT Change management events must be logged in accordance with the ICT Incident & Operational Event Management Guideline. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.12.2c.iii)

ID: 12 (version 2.0)	Change Management System
12 DOR.ICT.SDC.CMS.001	It must be ensured that tools and software are used to support the process wherever possible.
12.1 DOR.ICT.SDC.CMS.002	Tools must be used to ensure control and transparency of the whole ICT Change Management process. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: MaRisk 7.2 No 3 8.2 No. 1

4.1.2. Software Development

ID: 13 (version 2.0)	General software development process
13 DOR.ICT.SDC.GEN.001	It must be ensured that the software development process is systematically managed, controlled and is aligned with business, technical, and regulatory requirements throughout its lifecycle.
13.1 DOR.ICT.SDC.GEN.002	A structured secure software development process must be in place to manage and control the development of software successfully. Asset-Types: Business Process Key References: ICT Risk Framework 1.0
13.2 DOR.ICT.SDC.GEN.003	The process must at least cover specifications for: – Requirements determination – Development objective – (Technical) implementation (incl. programming Guidelines) – Quality assurance – Testing, acceptance, and approval – Secure repositories for source code and configuration – Roles and responsibilities in line with Segregation of Duties The process should cover specifications for: – Generation and update of Software Bill of Materials (SBOM) and Cryptography Bill Of Materials • (31.01.2027) Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.32
13.3 DOR.ICT.SDC.GEN.004	Developers must not deploy software to the Red and Yellow Segregation Area in their function as a developer. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.25
13.4 DOR.ICT.SDC.GEN.005	Depending on the protection need, it must be ensured that the confidentiality, the integrity, the availability, and the authenticity of all assets, whether directly involved or indirectly affected through dependencies, are maintained during development and after go-live. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool Key References: ISO 27001:2022 Cor 202203 A.8.25
13.5 DOR.ICT.SDC.GEN.006	Functional and non-functional requirements must be used and treated identically during the software development process. Asset-Types: Information, Business Process Key References: ISO 27001:2022 Cor 202203 A.8.25
13.6 DOR.ICT.SDC.GEN.007	Quality and security thresholds and corresponding controls must be defined, implemented, and assessed before IT Assets can be promoted to the next Segregation Area, e.g. Development (Green) to Test (Yellow/Blue) to

	Production (Red). These controls and thresholds are mandatory to be fulfilled. Asset-Types: Business Process Key References: ICT Risk Framework 1.0
13.7 DOR.ICT.SDC.GEN.008	ICT Systems in all Segregation Areas should be labelled, to reflect the respective Segregation Area (e.g. in window title or GUI). Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container Key References: ISO 27001:2022 Cor 202203 A.8.31

ID: 14 (version 2.0)	Secure system architecture and secure engineering principles
14 DOR.ICT.SDC.PRN.001	It must be ensured that secure system architecture, secure engineering principles and secure coding are in place.
14.1 DOR.ICT.SDC.PRN.002	Secure engineering principles must be established, documented, and applied. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, IDP Key References: ISO 27001:2022 Cor 202203 A.8.27
14.2 DOR.ICT.SDC.PRN.003	Processes and principles for secure coding as part of secure engineering must be established and at least cover: – Protection of source code against unauthorized access and tampering (e.g. versioning of source code) – Measures to mitigate risk from unintentional alteration or intentional manipulation – Use of security architecture principles (e.g. “security by design”, “least privilege”) Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool Key References: ISO 27001:2022 Cor 202203 A.8.28
14.3 DOR.ICT.SDC.PRN.004	Planning and prerequisites before coding which should be in place include: – Secure design and architecture – Secure coding standards – DBG-specific expectations and approved principles for secure coding Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool Key References: ISO 27001:2022 Cor 202203 A.8.25, A.8.27
14.4 DOR.ICT.SDC.PRN.005	Considerations during coding which should be in place include: – Secure coding practices specific to the programming language – Secure and structured programming techniques – Documenting code – Removing programming defects

	Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool Key References: ISO 27001:2022 Cor 202203 A.8.28
14.5 DOR.ICT.SDC.PRN.006	Review and maintenance after coding which should be in place include: – Updates should be securely packaged and deployed – Vulnerability scanning and mitigation of source code and third-party libraries in accordance with the ICT Patch and Vulnerability Management Guideline Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool Key References: DORA RTS RMF A.16.7, ISO 27001:2022 Cor 202203 A.8.25
14.6 DOR.ICT.SDC.PRN.007	If AI-assisted coding is used, additional source code analysis should be performed to detect AI based functions. Asset-Types: Self-developed DBG Application, Third-party-developed Application, Commercial-off-the-Shelf Solution, Underlying Software/Technology, No-Code/Low-Code Application, AI Model, Software Appliance Key References: Article 15 EU AI Act
14.7 DOR.ICT.SDC.PRN.008	AI-generated code should be explicitly marked to enable review by the developer. Reviewed code should be marked, if feasible. Asset-Types: Self-developed DBG Application, Third-party-developed Application, Commercial-off-the-Shelf Solution, Underlying Software/Technology, No-Code/Low-Code Application, AI Model, Software Appliance Key References: ISO 42001 A.6.2.3
14.8 DOR.ICT.SDC.PRN.010	Developers should document the prompts used for AI generated code (where feasible). Asset-Types: Self-developed DBG Application, Third-party-developed Application, Commercial-off-the-Shelf Solution, Underlying Software/Technology, No-Code/Low-Code Application, AI Model, Software Appliance Key References: ISO 42001 A.6.2.3
14.9 DOR.ICT.SDC.PRN.011	Peer review must be performed on all AI generated code sections. Asset-Types: Self-developed DBG Application, Third-party-developed Application, Commercial-off-the-Shelf Solution, Underlying Software/Technology, No-Code/Low-Code Application, AI Model, Software Appliance Key References: ISO 42001 A.6.2.4
14.10 DOR.ICT.SDC.PRN.012	AI-generated code must not bypass mandatory secure software development process and must be checked for hidden or unused functions and remote calls or external libraries. Asset-Types: Self-developed DBG Application, Third-party-developed Application, Commercial-off-the-Shelf Solution, Underlying Software/Technology, No-Code/Low-

	Code Application, AI Model, Software Appliance Key References: ISO 42001 A.6.2.4
--	--

ID: 15 (version 2.0)	Source code testing and verification
15 DOR.ICT.SDC.TST.001	It must be ensured that source code is tested and verified.
15.1 DOR.ICT.SDC.TST.002	In-house developed software and, where feasible, ICT third-party source code must be tested before implementing in the Red Segregation Area. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Operating System, Cloud PaaS, Container, Storage Key References: DORA RTS RMF A.16.3, A16.8
15.2 DOR.ICT.SDC.TST.003	Source code checks that must be carried out using both static and dynamic tests. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Operating System, Cloud PaaS, Container, Storage Key References: DORA RTS RMF A.16.3

ID: 16 (version 2.0)	Test management process
16 DOR.ICT.SDC.TMP.001	It must be ensured that the tests and their processes are fully designed and carried out so that all relevant aspects are sufficiently tested.
16.1 DOR.ICT.SDC.TMP.002	A test management process must be in place for testing ICT Systems before use and after maintenance. Asset-Types: Business Process, IDP Key References: DORA RTS RMF A.16.2
16.2 DOR.ICT.SDC.TMP.003	The tests must be designed as following: Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Storage Key References: DORA RTS RMF A.16.2
16.2.1 DOR.ICT.SDC.TMP.004	The extent of tests must be based on the criticality of the IT Assets and related business processes. Asset-Types: Business Process, IDP Key References: DORA RTS RMF A.16.2
16.2.2 DOR.ICT.SDC.TMP.005	The tests must be designed to verify that new ICT Systems perform as intended, including the quality of internally developed software. Asset-Types: Business Process Key References: DORA RTS RMF A.16.2

16.2.3 DOR.ICT.SDC.TMP.006	The tests must include security testing of software packages before implementing in Red Segregation Area. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Storage Key References: DORA RTS RMF A.16.4
16.3 DOR.ICT.SDC.TMP.007	The scope of tests must at least consider: – Functionality of the software – (Re-)Testing of security functions (ID 17) – Selection and protection of test data (ID 20) Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool Key References: ISO 27001:2022 Cor 202203 A.8.29
16.4 DOR.ICT.SDC.TMP.008	Appropriate test types must be developed, documented, and used for testing. Asset-Types: Business Process, IDP Key References: MaRisk AT 7.2 Tz. 3
16.5 DOR.ICT.SDC.TMP.009	Access controls for Blue and Yellow Segregation Areas must be defined according to the Identity and Access Management Guideline. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.33

ID: 17 (version 2.0)	Testing security functions
17 DOR.ICT.SDC.TSF.001	It must be ensured that security functions are thoroughly tested and validated.
17.1 DOR.ICT.SDC.TSF.002	Security functions must be tested, including (if relevant): – Authentication mechanisms – Access functions – Logging & Monitoring – Cryptographic mechanisms – Validation of input data – Audit-Logs – Handling of exceptions Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance Key References: ISO 27001:2022 Cor 202203 A.8.29

ID: 18 (version 2.0)	Test and development documentation
18 DOR.ICT.SDC.DOC.001	It must be ensured that the testing and development activities are properly documented.
18.1 DOR.ICT.SDC.DOC.002	The IT Application and its development must be documented in a way that is comprehensible for competent third parties. The documentation must include at least: – User documentation – Technical system documentation – Operating procedures and processes Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool Key References: ISO 27001:2022 Cor 202203 A.8.32
18.2 DOR.ICT.SDC.DOC.003	Test management documentation must at least contain the following: – Test case description – Test data – Expected test results – Realized test results – Actions derived from tests Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, IDP Key References: ISO 27001:2022 Cor 202203 A.8.29
18.3 DOR.ICT.SDC.DOC.004	The operating procedures and processes must be defined for each IT Application and be available to the respective operators of the IT Application. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance Key References: ISO 27001:2022 Cor 202203 A.8.19

ID: 19 (version 2.0)	Defect handling
19 DOR.ICT.SDC.DEF.001	It must be ensured that discovered defects are recorded and that the methods for addressing them are clearly defined.
19.1 DOR.ICT.SDC.DEF.002	Defects are identified, recorded, and eliminated prior to go live. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool Key References: ISO 27001:2022 Cor 202203 A.8.33
19.2 DOR.ICT.SDC.DEF.003	Defects must be documented. Asset-Types: Information, Business Process, Underlying Software/Technology, Tool, IDP Key References: ISO 27001:2022 Cor 202203 A.8.29
19.3 DOR.ICT.SDC.DEF.004	Defect handling and emergency defect handling must be defined.

	Asset-Types: Business Process, Underlying Software/Technology, Tool Key References: ISO 27001:2022 Cor 202203 A.8.29
--	---

ID: 20 (version 2.0)	Data Management
20 DOR.ICT.SDC.DAT.001	It must be ensured that data is adequately protected.
20.1 DOR.ICT.SDC.DAT.002	Data must be protected according to its integrity and confidentiality in all Segregation Areas. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Storage Key References: DORA RTS RMF A.16.5
20.2 DOR.ICT.SDC.DAT.003	Sensitive data must always be stored in the Red Segregation Area or the Yellow Segregation Area, provided the protection level meets or exceeds that of the Red Segregation Area. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Storage Key References: DORA RTS RMF A.16.5
20.3 DOR.ICT.SDC.DAT.004	Sensitive data must be anonymized, pseudonymized or randomized before it is copied to or stored in Green or Blue Segregation Area and must be approved by the Information Owner. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Storage Key References: ISO 27001:2022 Cor 202203 A8.11
20.4 DOR.ICT.SDC.DAT.005	Exceptions may be required where sensitive production data is needed for specific test occasions. For this, the following requirements must be fulfilled: – Approval by the responsible Information Owner – Alignment with Group Data Protection for personal data – Reporting and explanation when using sensitive production data for testing must be ensured – Data storage as well as user access must be time limited and removed afterwards Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Storage Key References: DORA RTS RMF A.16.6
20.5 DOR.ICT.SDC.DAT.006	Test data must be classified in accordance with the information classification scheme and should be protected accordingly. ⁷

⁷ For further information refer to the ICT Risk Management Guideline.

	Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Storage Key References: ISO 27001:2022 Cor 202203 A.8.33
20.6 DOR.ICT.SDC.DAT.007	Processes and procedures for data exchange between the respective Segregation Areas must be defined and followed. Asset-Types: Information, Business Process, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.31

4.1.3. Project Management

ID: 21 (version 2.0)	ICT Project Management
21 DOR.ICT.SDC.PMA.001	It must be ensured that the ICT projects are handled in an appropriate manner.
21.1 DOR.ICT.SDC.PMA.002	The ICT Project Management procedures must include: – ICT project objectives – ICT project governance – ICT project planning, timeframe, steps, and relevant milestones – ICT project risk assessment – Roles and responsibilities – Change management requirements – Testing of all requirements – Approval process for deploying IT Assets in Red Segregation Area Asset-Types: Business Process Key References: DORA RTS RMF A.15.3
21.2 DOR.ICT.SDC.PMA.003	ICT Project Management procedures that ensured effective management of ICT projects related to the acquisition, maintenance and development of ICT Systems must be developed, implemented, and documented. Asset-Types: Business Process Key References: DORA RTS RMF A.15.1, A.15.2
21.3 DOR.ICT.SDC.PMA.004	Risks across ICT projects must be captured and remediated. Asset-Types: Business Process Key References: DORA RTS RMF A.15.5
21.4 DOR.ICT.SDC.PMA.005	ICT projects affecting critical or important functions, and their risks must be reported to the management body either individually or in aggregate, based on the project's importance and size, and on a regular or event-driven basis. Asset-Types: Business Process Key References: DORA RTS RMF A.15.5
21.5 DOR.ICT.SDC.PMA.006	Any information or expertise required from the business areas or functions must be provided for the secure implementation of ICT projects. Asset-Types: Business Process Key References: DORA RTS RMF A.15.4

5. Roles and Responsibilities

5.1. Creator

The creator of the Software Development and ICT Change Management Guideline is the ICT Risk Governance & Advisory Unit (Specialist).

The creator of Software Development and ICT Change Management Guideline has the responsibility to issue clear, precise, and appropriate written rules to give guidance for implementation to the target group. It is important to ensure that all required information is accurate, up to date and complete.

5.2. Guideline Owner

The owner of the Software Development and ICT Change Management Guideline is Head of ICT Risk Governance & Advisory Unit.

The most important tasks (not an exhaustive list) within the scope of responsibility are:

- Ensure completeness of the Guideline within functional area of responsibility
- Ensure correctness of content and the Guideline is up to date
- Define and conduct adherence oversight measures for Guidelines on a regular basis
- Assess impact on the Guideline with major focus on requirements as well as roles and responsibilities in the event of organizational changes, new products etc.

The Guideline Owner has at least an Expert or Head of Unit level.

The Guideline Owner is responsible for publishing and updating the Software Development and ICT Change Management Guideline according to established procedures within the organization.

6. Appendix

6.1. Contact Information

Written Rule Owner: Head of ICT Risk Governance & Advisory Unit

Please contact ICT Risk **Governance & Advisory** in case of any questions related to this Guideline.

6.2. Document History

Document History

Version	Date	Changes & Background
1.0	17.01.2025	Initial set-up of this Guideline
1.1	15.08.2025	Annual Update Guideline
2.0	19.08.2026	Annual update with material changes

Coordination before publication

Version	Date	Task	Name
2.0	02.05.2026	Creator	ICT Risk Governance & Advisory Unit (Specialist)
	28.07.2026	Content Review	LE CISOs TISOs IT Ameli project
	28.07.2026	Content Confirmation	Head of ICT Risk Governance & Advisory Unit and LE CISOs

Approvals

Version	Date	Task	Name
2.0	13.08.2026	Approval	DBAG Chief Risk Officer

6.3. Related Written Rules

Superordinated Written Rules	ICT Risk Management Policy
Subordinated Written Rules	n/a

6.4. Abbreviations

The abbreviations in this document are defined in the overall ICT Risk Glossary, which is provided on the Intranet website.

***** END OF DOCUMENT *****
